



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

云安全证书应用实践



王高华

沃通电子认证服务有限公司
创始人&CTO



中国互联网安全大会



360互联网安全中心

议题

- 云安全建设中的“盲点”
- 云安全证书应用误区
- 云安全证书应用实践经验
- 基于CA体系的云安全框架
- SSL证书应用趋势



中国互联网络安全大会



360互联网安全中心

云安全建设中的“盲点”

1. 云安全建设中的“盲点”？

当提到云安全的时候，我们最常想到的是：

抗D攻击

云WAF

漏洞监控

入侵检测

却常常忽略最基础的安全防护措施

HTTPS加密

盲点

1. 云安全建设中的“盲点”？

利用HTTPS加密机制保护数据传输安全，从而确保数据完整性及保密性的作法已经相当普遍，但在云安全应用体系中，却常常容易被忽略。

我们都知道：安全性实际水平取决于体系中最薄弱的那一环(木桶理论)而**云服务没有进行HTTPS加密，相当于“木桶没有底板”**无需攻击或拖库，攻击者就能从明文流量中获取重要数据。



1. 云安全建设中的“盲点”？

云服务未启用HTTPS加密（SSL证书）的危害

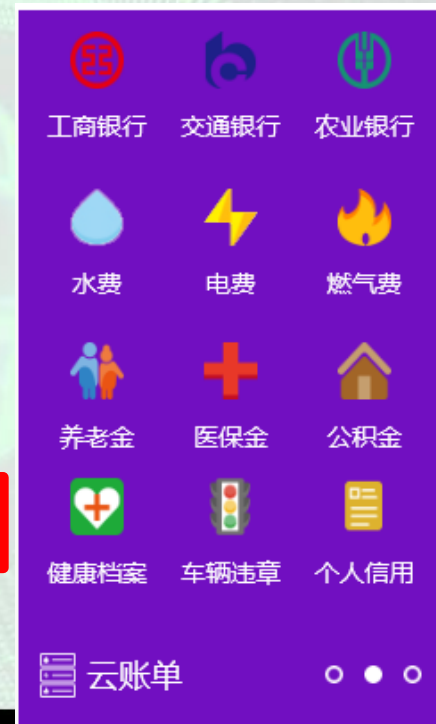
云服务未启用HTTPS加密，用户访问云服务时的所有通信数据，都在网络中“裸奔”；数据传输时不验证通信方身份，任何人都可以伪造虚假服务器欺骗用户。HTTP明文协议下，**数据窃取、数据篡改、流量劫持、身份冒用**变得轻而易举。



1. 云安全建设中的“盲点”？

■ 举例1：上海市民云：<http://www.eshimin.com/>

上海**市民云**就是给每个市民一个邮箱，但并没有部署SSL证书来保证用户账户安全、邮件内容安全和邮件系统安全。上海400万市民的所有隐私信息都在上面，只要市民连上免费WiFi(Web/APP)，所有公共事业账单、社保三金账单、信用卡账单、交通违章单、医疗健康档案等等都非常容易被非法截取，上海市民个人信息都在网上裸奔！



互联网+政务，如果不加上https ==个人隐私灾难！

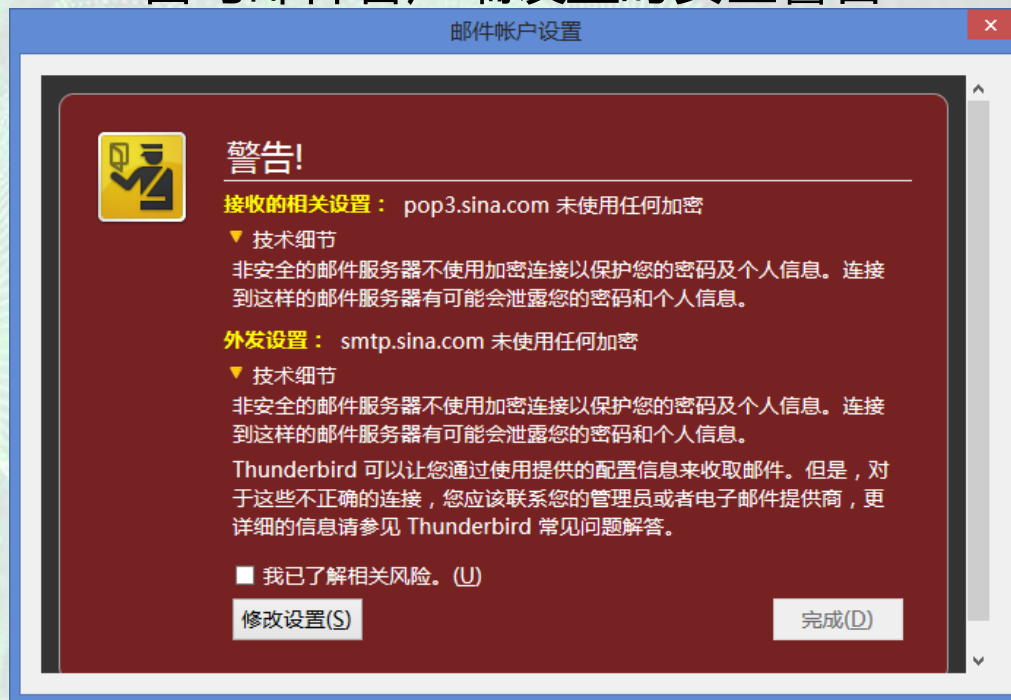
1. 云安全建设中的“盲点”？

■ 举例2：云邮箱服务未部署SSL证书，所有邮件等于明信片！

窃取实验：在办公室设立一个免费WiFi，隔壁公司就有人连上此WiFi后登录自己邮箱收邮件，由于邮件服务器没有部署SSL证书，是http明文提交用户名和密码到服务器，则可以非常容易地被抓包侦听软件截获用户名和密码，并成功收取用户的所有邮件。



雷鸟邮件客户端设置时安全警告：



1. 云安全建设中的“盲点”？

■ 举例3：某酒店预订App明文传输信息

通过简单的代理抓包工具就可以捕获该APP传输数据，其中可能包含用户的账号密码、身份证号、手机号、真实姓名、酒店预订记录、出行记录等隐私信息。

```
2015-11-19 10:15:03 POST http://mobile-api2011.elong.com/user/login?req=z6QQXjJp6u0ux7E1TUahhfNnUwF0C4lgti3tEF228EUYPlpKPaAee%2BvRJekBygqoHj smwrDAn2LgJu
7N0aooRQ%3D%3D&randomId=6be92096-0ae8-4672-9028-9d097feld1b6
- 200 application/octet-stream 272B 377ms

Request Response Detail
Server: EFE
Date: Thu, 19 Nov 2015 02:15:03 GMT
Content-Type: application/octet-stream
Content-Length: 272
Connection: keep-alive
Set-Cookie: route=629b2d40d73757386fda4ce9ec9a477d;Path=/
Expires: Thu, 19 Nov 2015 02:15:03 GMT
Cache-Control: max-age=0
Set-Cookie: NSC_fcplljoh.fmpoh.dpn_ofx_80=fffffffffa1d07c145525d5f4f58455e445a4a4229a0;expires=Thu, 19-Nov-2015 02:45:03 GMT;path=/;httponly
Raw [m:Auto]
{"AuthCode":"","CardNo":190000000043102681,"Email":"","ErrorCode":"","ErrorMessage":"","IsError":false,"Name":"","NeedVerifyCode":false,"PhoneNo":"13823
888888","RegisterDate":"2015-11-19 18:15","SessionToken":"fde5f21b-56e1-493f-a449-f5ec66b82ae2622","Sex":"N","UserId":0}
```

1. 云安全建设中的“盲点”？

■ 举例4：某零售APP明文传输用户账户/密码

某零售APP登录请求为明文HTTP，用户账户/密码一览无遗。

```
<?xml version="1.0" encoding="UTF-8"?><v:Envelope  
xmlns:i="http://www.w3.org/2001/XMLSchema-instance"  
xmlns:d="http://www.w3.org/2001/XMLSchema"  
xmlns:c="http://schemas.xmlsoap.org/soap/encoding/"  
xmlns:v="http://schemas.xmlsoap.org/soap/envelope/"><v:Header /><v:Body><Login User  
xmlns="http://photochannel.com/webservices" id="o0" c:root="1"><sessionID i:type="d:string">  
120C6mf1_cVQE394QKN5qaYJzixEJfzuU0dHqR9biDaqetKzP3,zmxsDqSyKR1  
_inZtE6ApKnf3POMz3FDW6...</sessionID><retailerID i:type="d:string">27</retailerID><login  
i:type="d:string">fake@email.com</login><password i:type="d:string">myfakepassword</password  
</Login User></v:Body></v:Envelope>
```




中国互联网络安全大会



360互联网安全中心

云安全证书应用误区

2. 云安全证书应用误区

应用误区：为了HTTPS而HTTPS

仅仅为了显示HTTPS连接，而错误地部署应用HTTPS，使SSL安全策略形同虚设，以下是**最常见的应用误区**：

(1) 使用自签名证书

自签名SSL证书可以随意签发，没有第三方监督审核，不受浏览器信任，常被用于伪造证书进行中间人攻击，劫持SSL加密流量。有些证书长达20年！

(2) 使用淘汰的加密算法

SSL证书仍使用已被国际标准淘汰的加密算法，如：仍使用SHA-1签名算法的SSL证书。

(3) 没有正确配置服务器

部署证书后就万事大吉，没有检测服务器配置。如：服务器仍在使用的TLS1.2以下版本协议；未及时修复各自相关协议漏洞；仍支持脆弱的密钥交换算法……

2. 云安全证书应用误区

(4) 部署多个负载均衡服务器，只使用1张SSL证书

为节省证书成本，部署大量负载均衡服务器或通配域名时，只使用一张SSL证书，一旦一台服务器出现问题，所有服务器都会受到影响。重新部署证书的成本远远大于为每台服务器单独购买一张证书的成本！

(5) 采用“弹性SSL”配置云CDN服务

无需在源服务器上设置HTTPS，但访客可以通过CDN服务商提供的有效证书用HTTPS连接访问网站。但是事实上从源服务器到CDN服务商之间的连接不一定是安全的，这种看似极具吸引力的配置方式，给访客产生极大的误导，误以为与网站的通信连接是全程安全的。

(6) 移动APP与云服务器通信不验证服务器端的SSL证书的有效性

有些APP启用了https通信，但不判断服务器证书是否是可信的证书，是否的确是APP应该提交数据的服务器。仅指定服务器的域名是不安全的，容易遭遇DNS劫持后截获所有用户机密信息。必须验证证书链和证书绑定的域名是否正确。



中国互联网络安全大会



360互联网安全中心

云安全证书应用实践经验

微软Azure云、阿里云如何应用SSL证书？

3. 云安全证书应用实践经验



云安全证书的选择标准：

(1)全球信任

只有支持所有浏览器和所有终端设备的全球信任的SSL证书，才能起到安全和认证的作用。全球信任的SSL证书符合最新国际标准操作规程，采用最安全的加密算法和签名算法，让用户获取到安全合规的SSL证书。

(2)支持CT证书透明度

为防止CA证书恶意滥用的问题，选择的SSL证书应该支持CT证书透明度，确保签发的每一张SSL证书都透明可信。

(3)及时快速的服务响应

云服务涉及用户重要系统和资源，一旦出现任何问题，及时快速的服务响应支持，可帮助云服务商和用户将损失降至最低。

(4)政策合规性

微软Azure云和阿里云，都谨慎应对政策合规性问题，合作的厂商均为国产SSL证书厂商。由此可见，把政策合规性纳入安全产品选购标准是很有必要的。

3. 云安全证书应用实践经验



云安全证书应用经验：

(1) 技术应用（针对用户）：

- 使用权威CA机构签发的全球信任的SSL证书；
- 使用遵守最新国际标准算法的SSL证书；
- 正确配置服务器，定期做SSL安全体检；
- 重要系统网站，为每台服务器部署独立的SSL证书。

(2) 合作模式（针对云服务商）：

- 云服务商可通过API接口为用户提供全球信任度的SSL证书服务；
- 云服务商自动部署SSL证书到云产品中，降低SSL部署难度；
- 每台云服务器必须有一张SSL证书用于身份认证和内部通信加密。

3. 云安全证书应用实践经验-微软Azure云

案例分享一：微软云Azure SSL证书应用实例经验分享

(1) 微软云平台中每台服务器都部署一张独立服务器SSL证书，即使是不对外提供服务的服务器，这些证书不仅用于服务器之间**加密通信**和用户与服务器之间的加密通信，而且还用于服务器之间通信时的**身份认证**。



3. 云安全证书应用实践经验-微软Azure云

- (2) 微软云平台中每台服务器都独立部署一张服务器证书，即使是同一域名，这样不仅能保证服务器身份的唯一性(证书唯一指纹、唯一私钥)，而且需要吊销证书时也方便管理，一台服务器出现问题不会影响其他服务器。

指纹	主题
D0A4FED06ED7D900A9C2824831451D4315E3C18C	*.prod.azureservicedeploy.chinacloudapi.cn
FB9868533BFA1AB77C835E66C13492B2C08D1204	*.prod.azureservicedeploy.chinacloudapi.cn
4C31F3B418251B8D3E0680E4A3E4068D705CB62E	*.prod.azureservicedeploy.chinacloudapi.cn
BC598EA9DF36FC770A5688AF2A92F48BD4E4A754	*.prod.azureservicedeploy.chinacloudapi.cn
774E065271BA95B1140476ABF1A62ECEC0BDDFE7	*.protection.partner.outlook.cn
413FC34140FFC5773B2D5369A09AF9E22EA98272	*.protection.partner.outlook.cn
E1459B36C05002A70DAAA92A1B38347ED89E8F59	*.protectioncn.partner.outlook.cn
A394C1196CDD211073FE031D5984AEEF1AE20961	*.relex.portal.windows.azure.cn
B247E3AF444D681B07D9659B67EA45FF4F72DCBE	*.relex.portal.windows.azure.cn
9FB96FB241581FAD7CCBD7FAFDF0C4CB369E17DA	*.relex.portal.windows.azure.cn
94539C55B0310E033A945423DF5C8462C9EB9D40	*.relex.portal.windows.azure.cn
FD44E23958E9505BF4B0C0768F639DCBB8868637	*.relex.portal.windowsazure.cn

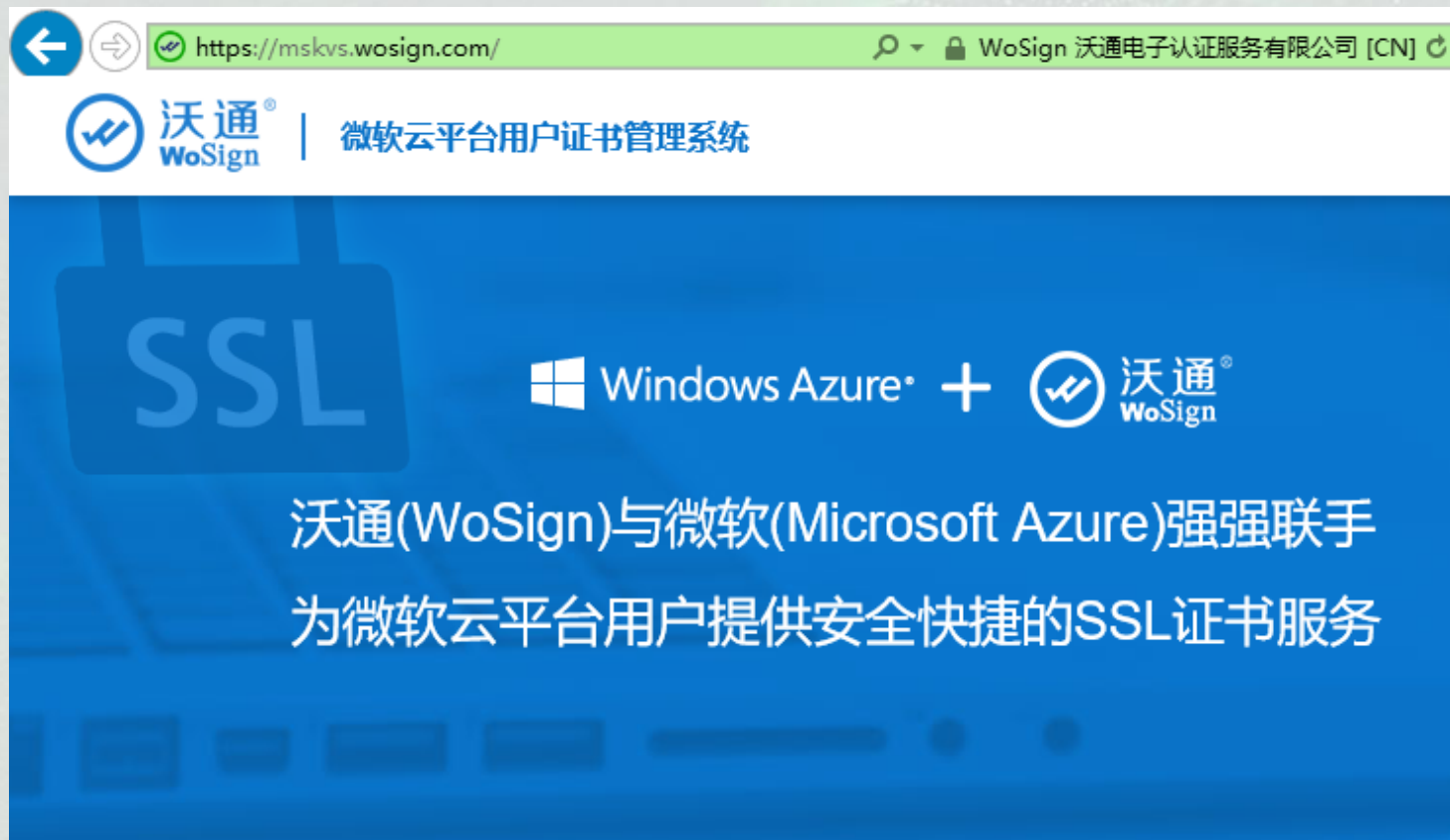
3. 云安全证书应用实践经验-微软Azure云

(3) 为每个部署SSL证书的服务器体检，并修复各种安全漏洞，确保安全地使用HTTPS。



3. 云安全证书应用实践经验-微软Azure云

- (4) 为微软Azure云平台用户配套提供SSL证书，确保用户的系统安全。
利用WoSign SSL API接口实时快速为云用户系统部署SSL证书。



3. 云安全证书应用实践经验-阿里云



案例分享二：阿里云的SSL证书服务模式

阿里云推出云盾证书服务，在阿里云平台上集成沃通SSL证书API接口，阿里云用户可以在云平台上直接购买甚至免费获取所需的SSL证书，一键部署在阿里云产品中，将所持云服务从HTTP自动转换成HTTPS。

阿里云首页 管理控制台 帮助与文档

云盾证书服务

配置参数

保护类型：

1个域名 多个域名 所有子域名

域名个数：

1个

证书类型：

免费版 SSL 普通版DV SSL 专业版OV SSL 高级版EV SSL

选择品牌：

WoSign

沃通电子认证服务有限公司(WoSign CA)是权威可信的数字证书颁发机构，通过WebTrust国际认证及工信部许可，是国际CA浏览器联盟组织成员。沃通SSL证书支持所有浏览器和移动终端，严格按照国际标准和CPS做身份鉴证。国内市场占有率位居前列，性价比高，提供7x24小时顶级服务支持。有完善的风险承保计划。

购买时长

购买时长：

1年 2年

3. 云安全证书应用实践经验-阿里云



(1) SSL证书API接口集成

通过API接口，直接在阿里云平台在线申请证书、提交验证材料、管理证书状态、自动部署证书、在线吊销证书等操作，一站式完成SSL证书购买、审核和快速应用。

The screenshot displays the Alibaba Cloud management console for the CA Certificate Service. The left sidebar lists various services, with 'CA证书服务' (CA Certificate Service) selected. The main content area shows the '我的证书' (My Certificates) tab, which includes a table for certificate details. The table has columns for '订单号' (Order ID), '证书绑定域名' (Certificate Binding Domain), '年限' (Term), '证书品牌(所有)' (Certificate Brand), '到期时间' (Expiration Time), '证书状态(全部)' (Certificate Status), and '操作' (Action). A message indicates that no records were found: '没有查询到符合条件的记录'.

订单号	证书绑定域名	年限	证书品牌(所有)	到期时间	证书状态(全部)	操作
没有查询到符合条件的记录						

3. 云安全证书应用实践经验-阿里云



(2) SSL证书一键推送部署

阿里云云盾证书服务和阿里云产品打通，在线完成SSL证书申请后，可一键推送到阿里云产品中，自动完成证书部署，缩短SSL证书申请时间，降低HTTPS实施难度。目前，阿里云云盾高防IP产品已经率先打通SSL证书推送服务，云盾WAF防火墙/CDN/SLB/云邮箱等产品也将陆续开启。

证书详情 [返回上级列表](#)

订单号: 10000004447296400005

订单状态: 已签发

证书信息

云产品推送

产品名称	推送时间	状态	操作
高防IP	2016-04-08 19:00:26	未推送	推送



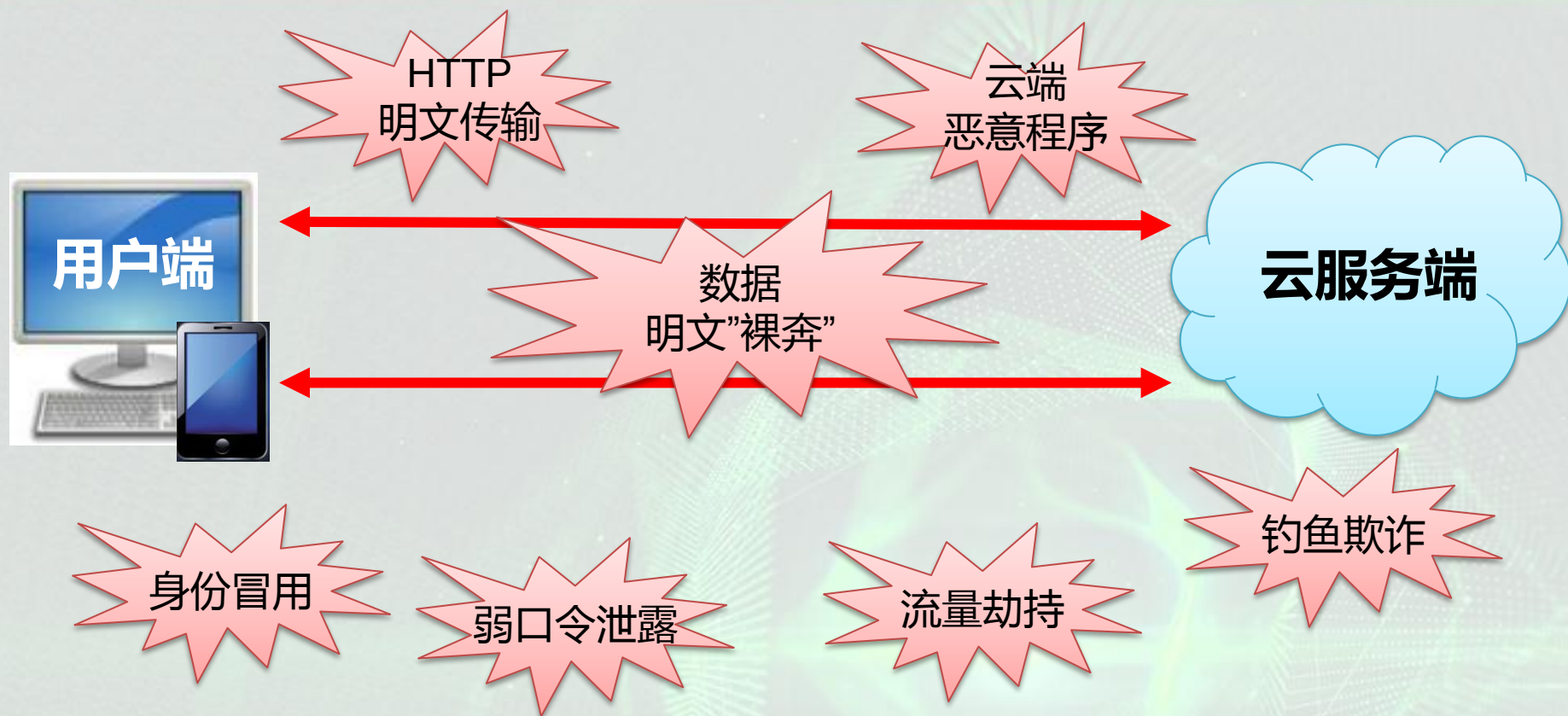
中国互联网络安全大会



360互联网安全中心

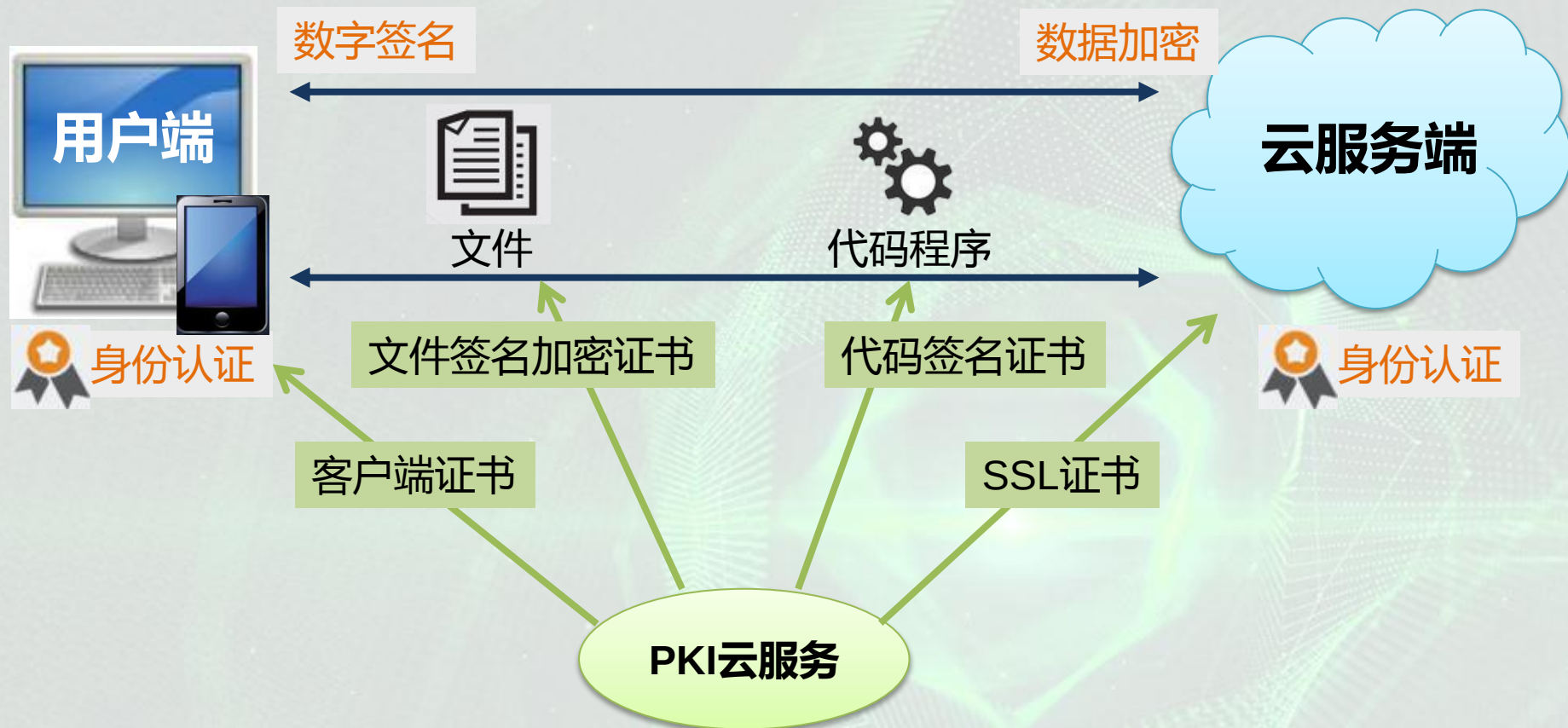
基于CA体系的云安全框架

4.基于CA体系的云安全框架



未使用PKI/CA体系，云服务将面临的安全问题

4.基于CA体系的云安全框架



基于PKI/CA体系的云安全框架

4.基于CA体系的云安全框架



中国互联网安全大会



基于PKI/CA体系的三种数字证书（SSL证书、代码签名证书和客户端证书），都可以应用于云安全体系中，保障云服务的安全可信：

（1）SSL证书：加密所有通信

- 服务器与服务器之间加密及身份认证
- 客户端/移动APP与服务器之间传输加密及身份认证
- 各种API接口
- 邮件服务器SSL POP/SMTP/IMAP

4.基于CA体系的云安全框架

(2) 代码签名证书：认证代码程序

认证云内应用程序开发者真实身份，确保程序来源可信；对程序进行数字签名，确保程序在云端没有被非法篡改或植入病毒木马；

- CA为云服务平台（SaaS）提供API接口，云平台用户通过云平台获取代码签名证书，为代码程序签名后，配置到云端服务中，终端用户访问云端应用程序时，自动验证程序来源可信，未经非法篡改。

一个平台签名，在一个平台发布

- 代码托管云平台通过API接口，对云端发布的应用程序/可执行文件进行签名，程序可作为第三方服务配置到其他（SaaS）云服务平台上。终端用户使用云服务时，触发该程序，可自动验证程序来源可信，未经非法篡改。

一个签名程序，发布到多个平台

4.基于CA体系的云安全框架

(3) 客户端证书：身份认证、访问控制和文件加密

云计算系统应建立基于数字证书的统一、集中的认证和授权系统，以满足云计算多租户环境下复杂的用户权限策略管理和海量访问认证要求，提高云计算系统身份管理和认证的安全性。云平台用户可以通过API接口获取数字证书。

- 安全访问

采用客户端认证，对不同类型和等级的系统、服务、端口采用强身份认证登录。

- 权限划分

根据用户、用户组、用户级别的定义来对云计算系统资源的访问进行集中授权。

- 行为追溯

基于客户端证书的用户访问日志记录，访问行为追溯。

- 文件加密

基于客户端PDF证书的文件签名加密放在云中的所有文件，不是简单的自编算法加密，必须用用户的客户端证书加密各种文件保存在云端，用户下载到自己的电脑用证书私钥解密。

4.基于CA体系的云安全框架



中国互联网安全大会



360互联网安全中心

(4) 可信计算EK证书

用服务器主板中内置的可信计算EK证书来加密用户的文件系统，仅在启动实例时解密；用EK证书签名所有系统文件，在系统运行时验证这些文件，确保系统可信。



中国网络安全大会



360互联网安全中心

SSL证书应用趋势

5.SSL证书应用趋势

(1) 谷歌要求SSL证书支持CT证书透明

目前谷歌要求所有EV SSL证书必须支持CT证书透明度，所有签发的证书都提交到公共CT Log服务器，否则不显示EV绿色地址栏，防止SSL证书被恶意使用，确保签发过程透明可信。沃通WoSign、StartCom等领先CA都已率先实现所有SSL证书支持CT证书透明。



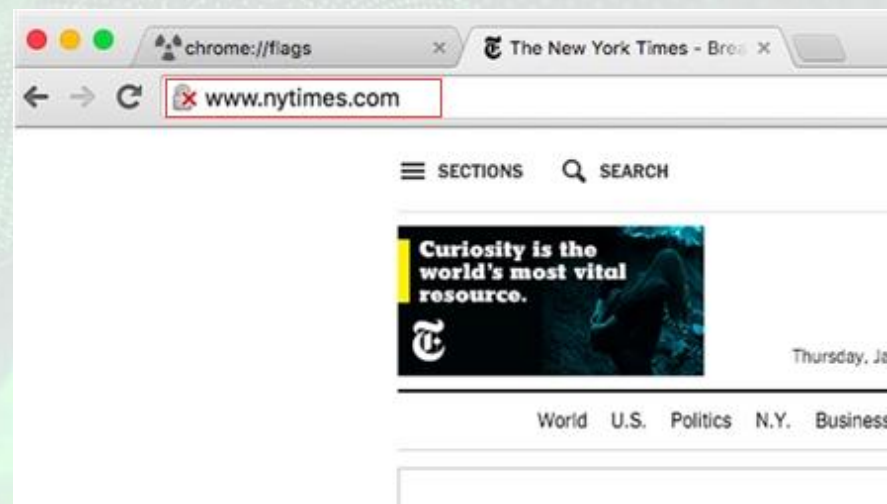
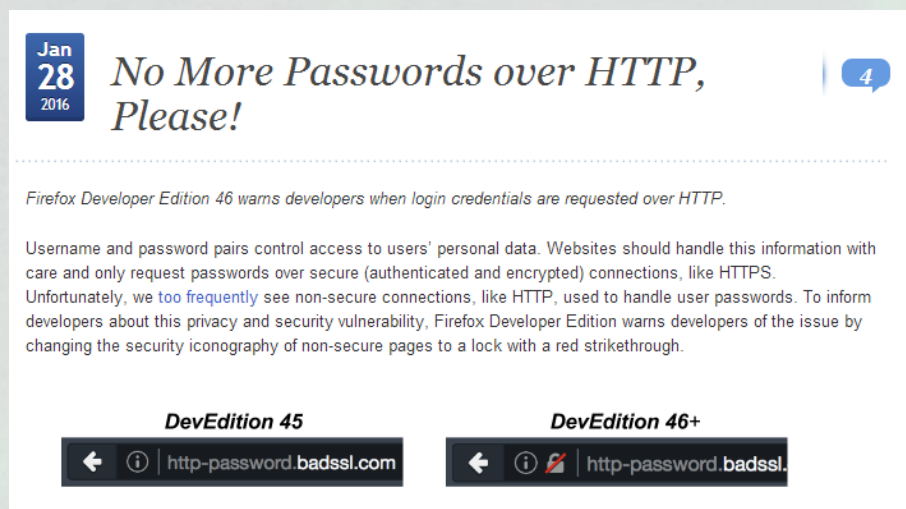
(2) 苹果App强制开启ATS标准

苹果宣布2017年1月1日起，所有提交到App Store 的App必须强制开启ATS安全标准(App Transport Security)，所有连接必须使用HTTPS加密。

5.SSL证书应用趋势

(3) 谷歌、火狐浏览器将对HTTP页面提出警告

- 密码提交页面无HTTPS加密，火狐浏览器将会给出一个红色的阻止图标；
- 谷歌Chrome浏览器则计划将所有HTTP网站都打红叉。



(4) 停止支持SHA-1算法

2015年12月31日全球CA必须停止签发SHA1签名算法的SSL证书，代码签名证书和客户端证书不强制但推荐加紧升级到SHA2！2016年12月31日之后所有操作系统将不再信任SHA1签名算法的SSL证书。

5.SSL证书应用趋势

(5) 英美强制要求所有政府网站启用HTTPS加密

- 美国政府于2015年6月8日发布了要求所有政府网站都必须在**2016年12月31日之前**完成全站https加密！这是确保政府网站信息的安全，保护美国公民的网上隐私。截至7月15日，已经有50%政府网站已经实现全站https。



5.SSL证书应用趋势

(5) 英美强制要求政府网站启用HTTPS加密

- 英国要求所有政府网站于**2016年10月1日起**强制启用全站HTTPS加密，还计划将service.gov.uk提交至浏览器厂商的HSTS预加载列表，只有通过HTTPS才能访问政府服务。



谢谢
WWW.WOSIGN.COM

